Mini Project 3: Build a RAG System for Your Own Data

Justin Garter
IT7075C Applied AI for Cybersecurity, Dr. Zag ElSayed
University of Cincinnati, October 2026

Video: https://youtu.be/j3j0q26ge64
Project folder: https://github.com/justin-garter/IT7075-coursework/tree/main/module04/rag_project

Summary

I built a RAG system over five excerpts of the federal rules that govern defense and aerospace contractors: DFARS cyber clauses, the CMMC program rule and ITAR. At the baseline settings (600-character chunks, k = 4, distance threshold 0.75) retrieval found the evidence for all six answerable questions and refused the off-topic question. No setting refused the on-topic question my documents can't answer, because its closest chunk is nearer than most real answers. The distance threshold was the setting that mattered most.

1. How the system works

Embeddings. The model all-MiniLM-L6-v2 turns any piece of text into a list of 384 numbers. It was trained so that texts with similar meaning end up with similar numbers, so the cosine distance between two vectors works as a measure of meaning: 0 is identical, and around 1 is unrelated. That's what lets the system search by meaning instead of by keyword. Q1 asks how quickly a contractor has to report an incident, and its closest chunk is the DFARS definition "Rapidly report means within 72 hours," at distance 0.387, even though the word "quickly" never appears in my documents. The same model has to embed both the chunks and the question, or the distances mean nothing.

Chunking. One vector can't represent a whole document that covers several topics, so each file is cut into 600-character pieces that overlap by 100 characters. The overlap keeps a sentence that lands on a boundary from being lost to both pieces. Chunks that are too large average several topics into one vector, which dilutes the sentence you're looking for and fills the prompt with unrelated text. Chunks that are too small split a phrase across two pieces and strip the context that makes it match. My data showed both: 200-character chunks missed Q3, and 800-character chunks missed Q4.

Vector database. ChromaDB stores four things per chunk: an ID, the chunk text, its embedding and metadata recording the source file. Given a question's embedding, it returns the k nearest chunks with their text, distance and source. It always returns k chunks, however poor the match, so my retrieve() function drops anything farther than the threshold. An empty result is what turns into a refusal.

The three steps of RAG, and where each appears in the notebook:

Step	Code	Notebook location
Retrieve	retrieve()	Part 3 (TODO 3); called by my_ask() in the YOUR RAG cell
Augment	build_context(), MY_SYSTEM	Part 4 (TODO 4); MY_SYSTEM prompt in the YOUR RAG cell
Generate	generate_local()	YOUR RAG cell: mistral:7b through Ollama on 127.0.0.1:11434, temperature 0

Before using my own data, I completed the five practice TODOs on the course documents and matched the expected output: 22 chunks, found 6/6 and refused 2/2. The practice section generated answers offline, because no API key was used.

2. What I built

My topic is cybersecurity compliance for aerospace and defense manufacturers, the field I want to work in. Every company that handles controlled defense information has to follow these rules, and the questions have exact, checkable answers. All five documents are copied word for word from the eCFR. Federal regulations are public domain, and my_kb/SOURCES.md links each one.

File	Regulation	Characters
dfars_7012.md	48 CFR 252.204-7012, safeguarding and incident reporting	2,300
cmmc_levels.md	32 CFR 170.15 to 170.18, CMMC levels and assessors	1,857
cmmc_poam_affirmation.md	32 CFR 170.21, 170.22, POA&M rules and affirmation	1,777
sprs_assessments.md	48 CFR 252.204-7019, 7020, DoD assessments and SPRS	1,678
itar_basics.md	22 CFR 120 and 122, ITAR definitions and registration	2,257
Total		9,869

ID	Question	Evidence phrase (or why it's unanswerable)
Q1	How quickly does a defense contractor have to report a cyber incident to the DoD?	within 72 hours of discovery of any cyber incident
Q2	How long must a contractor keep images of affected systems after reporting a cyber incident?	for at least 90 days from the submission of the cyber incident report
Q3	Who performs a CMMC Level 3 certification assessment?	which will be performed by DCMA DIBCAC
Q4	What minimum score does a contractor need to get Conditional Level 2 status with a POA&M?	is greater than or equal to 0.8
Q5	How many business days does a contractor get to provide additional evidence for the findings of a Medium or High assessment?	the contractor has 14 business days to provide additional information
Q6	Does showing technical data to a foreign national inside the US count as an export under ITAR?	to a foreign person in the United States (a deemed export)
Q7	What is the top track speed of the 2024 Kawasaki Z500 SE?	Off-topic
Q8	How many security requirements are in NIST SP 800-171 Revision 3?	On-topic, absent: my files only cover Revision 2

I chose Q8 because it looks exactly like something my documents should answer. My SPRS file names NIST SP 800-171 five times and gives 110 as the maximum assessment score, which is the number of requirements in Revision 2. Revision 3 is a real, current publication, but none of my files describe it. A system that answers "110" is giving a confident, wrong answer pulled from the wrong revision, which is the kind of mistake that hurts in a real compliance review.

3. What my experiments showed

I started from the baseline (chunk 600, overlap 100, k = 4, threshold 0.75) and changed one setting at a time, scoring each configuration against all eight questions. Found means a retrieved chunk contained the evidence phrase. Refused means nothing was retrieved.

Setting varied	Value	Chunks	Found (of 6)	Refused (of 2)	Missed
chunk_size	200	100	5	1	Q3 Q8
chunk_size	300	52	6	1	Q8
chunk_size	400	35	6	1	Q8
chunk_size	600	22	6	1	Q8
chunk_size	800	17	5	1	Q4 Q8
chunk_size	1000	13	6	1	Q8
chunk_size	1500	10	6	1	Q8
k	1	22	5	1	Q5 Q8
k	2	22	6	1	Q8
k	3	22	6	1	Q8
k	4	22	6	1	Q8
k	6	22	6	1	Q8
k	8	22	6	1	Q8
threshold	0.4	22	2	1	Q2 Q4 Q5 Q6 Q8
threshold	0.5	22	5	1	Q5 Q8
threshold	0.6	22	6	1	Q8
threshold	0.65	22	6	1	Q8
threshold	0.7	22	6	1	Q8
threshold	0.75	22	6	1	Q8
threshold	0.8	22	6	1	Q8
threshold	0.9	22	6	0	Q7 Q8
threshold	1.0	22	6	0	Q7 Q8

Table 1. Task 4: results.csv. Every configuration misses Q8.

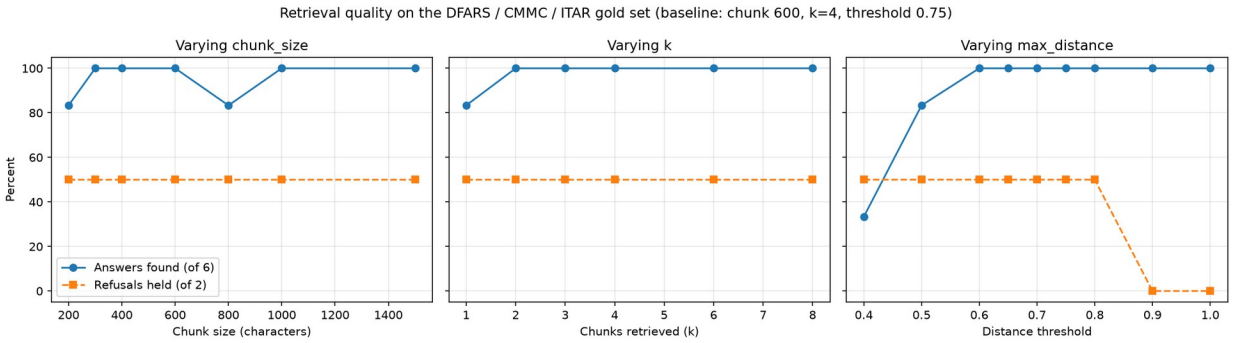


Figure 1. Task 4: answers found and refusals held for each setting (figure.png).

The distance threshold mattered most. At 0.4, retrieval found only 2 of 6 answers. At 0.9 and above it still found all 6, but it stopped refusing Q7, whose nearest chunk sits at 0.854. That's the trade-off the assignment warns about: a looser threshold looks just as good on answers while the system starts guessing. The safe range on my data is 0.6 to 0.8, between Q5's closest chunk at 0.503 and Q7's at 0.854.

Chunk size and k mattered much less. Each one cost a single answer at one extreme: chunk 200 missed Q3, chunk 800 missed Q4 and k = 1 missed Q5. Refusals didn't change at all, because they depend on distance, not on how many chunks come back.

Settings I would use: chunk 600, overlap 100, k = 3, threshold 0.70. That keeps all six answers, leaves a margin on both sides of the threshold and puts one less chunk of noise in the prompt than k = 4.

4. One question my system got wrong

Q8 failed at every setting. Retrieval returned four chunks, and the model labeled its answer as grounded:

```
Q: How many security requirements are in NIST SP 800-171 Revision 3?
   retrieved  distance 0.352  [sprs_assessments.md]
   retrieved  distance 0.463  [sprs_assessments.md]
   retrieved  distance 0.466  [sprs_assessments.md]
   retrieved  distance 0.488  [cmmc_poam_affirmation.md]
   answer: [RAG] The context does not provide a specific number for the total
   number of security requirements in NIST SP 800-171 Revision 3. ...
   [source: nist_sp_800_171_rev3.pdf]
```

Transcript excerpt from the YOUR RAG cell of rag_notebook.ipynb.

The closest chunk, at 0.352, is chunk 0 of sprs_assessments.md. It holds the file's heading, "NIST SP 800-171 DoD Assessments and SPRS," and the definitions of a Basic Assessment and a High Assessment, which repeat the publication name and include the words "Assessing Security Requirements." It doesn't contain a requirement count at all. The chunk that states 110, chunk 2, wasn't even retrieved.

The mistake is that the embedding matched the question's topic, not the fact it asks for. Q8 shares its key terms with that chunk: "NIST SP 800-171" and "security requirements." The words that make it unanswerable, "Revision 3," are a small detail that barely moves a 384-number vector. The heading I added to each file made it worse, because it puts the publication name at the top of chunk 0.

Generation partly caught the problem: the model didn't state a number. But it still tagged the answer [RAG], and it cited a file named nist_sp_800_171_rev3.pdf, which doesn't exist anywhere in my knowledge base. A threshold can't fix this, because the bad match is closer than four of my six correct answers. Catching it would take a check at the answer level, such as verifying that every cited file exists and that the answer contains text from the retrieved chunks.

For contrast, Q7 worked the way a refusal should. Its nearest chunk was 0.854 away, nothing passed the threshold, and the model answered [LLM] and said it didn't know.

5. What my evidence does not tell me

- **The sample is tiny.** With six answerable questions, one miss moves found by 17 percentage points. With two unanswerable questions, one miss moves refused by 50. Configurations that differ by a single question aren't meaningfully different.
- **Found measures retrieval, not the answer.** Q4 counted as found, but the model attached the encryption exception from paragraph (ii) to the 0.8 score rule in paragraph (i), so the answer is partly wrong. Q8 counted as a miss, but the model never gave the wrong number.

- **I wrote the questions with the documents open.** My wording overlaps the regulation text more than a real user's would, so these distances are probably better than real traffic would produce.
- **One embedding model and one corpus.** The safe threshold range of 0.6 to 0.8 belongs to all-MiniLM-L6-v2 on these five files. It would have to be measured again for a different model or a larger knowledge base.

Generative AI use

I used Claude (Anthropic) to pull the regulation text from the eCFR, fill in the five practice TODOs, write the Part 6 code and README, and draft this report. I chose the topic, reviewed and edited the questions, ran every cell myself and recorded the video.